Legend

Prereq 0.x – Icons & Preamble
- Prereq 0.1 – Starting your practice/competition
- Prereq 0.2 – Team ID
- Prereq 0.3 – General things to avoid
- Prereq 0.4 – Scoring report

1.x – Readme
- 1.1 – Readme Scenario
- 1.2 – Readme Critical Services
- 1.3 – Readme Users

2 – Forensic questions
3 – Firewall
4 – SSH (**Linux** only)
5 – Finding unwanted files / Hashes
6 – Removing unwanted programs
7 – Users & Groups
8 – Updating
9 – SMB/Samba shares
10 – Local Security Policy (**Windows** only)
11 – Roles and Features (**Windows** only)
12 – Group Policy (**Windows** only)
13 – Remote Desktop Protocol (**Windows** only)
14 – Internet Information Services (IIS) Manager (**Windows Server** only)
15 – Cron (**Linux** only)
16 – Windows Defender (**Windows** only)
17 – Windows Services (**Windows** only)
18 – Listing programs
19 – Ports
20 – Pam/General Security

Prereq 0.x – Icons & Preamble

In this guide, I use **Windows** and **Windows Server** interchangably at times because they are very similar.

For this manual, I know some people's brains work visually and the heavy amounts of text below might get hard to parse, so below are some images to relate to the text. *(and to help you navigate the machines) The images on the right represent what each of the virtual machines looks like when the Start/App menu is open.*

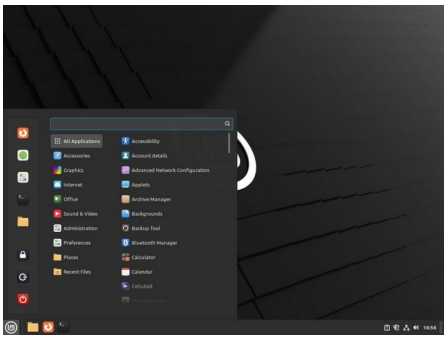
Windows:

Control Panel
File Explorer
Local Security Policy
Computer Management
Powershell
Command Prompt
Services
Internet Information Services (IIS)



Linux Mint:

Settings/Preferences
File Manager
Terminal
Start Button



Ubuntu:

Terminal
Settings
App Menu
Files
Software & Updates



Prereq 0.1 – Starting your practice/competition

Before you can practice or compete, you need to start the scenario's virtual machine. On your machine's Desktop you should see a **yellow folder** with the word "Competition" or "Practice Image" in the name. Click it, and navigate until you see a bunch of loose files. Among these, you should look for one with an icon resembling three windows or squares  . This is the icon you should double-click to start up the scenario's virtual machine. Once VMWare has opened, click the green  play button, and the machine will start. You can safely ignore the popups that VMWare will give you.

Prereq 0.2 – Team ID

This is needed before any competition or training may begin. Once you start any virtual machine, you should have a popup to enter your unique ID (found on the front of your team's booklet under your team's name) weither automatically or manually through an icon on your desktop. Make sure to:
a) Use **your** team's ID. (especially during competition)
b) Use the appropriate ID for the occasion. (practice or competition)

Of note: Some images might say you entered the code correctly and yet still show contradicting information like "This image does not have a README yet" upon opening the README. In that case, try entering your ID again. If that does not work after numerious tries, check to make sure your virtual machine has internet, then consult your team leader or Mr. Simms.

Prereq 0.3 – General things to avoid

Please **do not** change the password for **your** user account *(see the 1.3-Readme Users)* as this could force you to restart from scratch if you forget what it is. Vital things like **`sudo`** on linux, or administration prompts on **Windows** require this.

Please check out the Forensic Question(s) *(see section 3-Forensic Questions)* before making **any changes to the system.** For example, if the question requires you to find "goose.exe," it may become impossible if removed before reading the Forensic Questions.

If you feel lost or have no idea what to do either during competition or during practice then please feel free to talk to your team leader. *We will try and get it sorted out the best we can!* Also, feel free to search up questions with your preffered search engine on another machine. Google isn't against the rules!

Prereq 0.4 – Scoring report

The "Scoring report" is one of the few icons on your desktop with a CyberPatriot icon. It contains a log and tally of your current score detailing what you got correct or incorrect. If your scoring report cannot connect to the cyberpatriot servers, your virtual machine may have had it's internet mismanaged, or your team ID has not been entered yet.

1.x – Readme

The very first thing you should do after entering your team ID is check the **README**. It is located on the D**esktop** with a **CyberPatriot** icon and contains *very, very vital* information in regards to getting points and destroying the other teams.

It contains what and what **not** do to at any point during competition or practice. Give every paragraph of the README a read before checking the Forensic Questions and getting some points. The README is normally divided up into sections. The first is usually competition guidelines *(The same on every CyberPatriot README, user-made ones may differ),* below is a list of the unique sections:

1.1 – Readme Scenario

This section dictates what you can/cannot do in this scenario. For example,

> The tribes have agreed that our security policies must require all user accounts be password protected. Tribes are required to choose secure passwords; however, this policy may not be currently enforced on this computer. It is very important to **write down all passwords you change**. The presence of any non-work related media files and "hacking tools" is strictly prohibited. We currently do not use any centralized
>
> Please create the group “unviable” with the users quetzali, xin-xi, and oumaji at your earliest convenience.

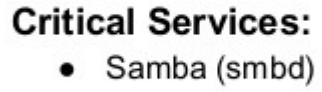
In this example, the scenario dictates that “hacking tools” ought to be removed. *(check Section 6-Removing unwanted files) Note: Remember to check the Forensic questions before removing these tools – they might be rquired!* It also dictates that all users should have secure passwords. *(see section 7-Users & Groups)* And, that the group “unviable” should be created with various users. *(Also in section 7)* Continuing on, most README’s have the version of the system, then more in-depth info.

> **Ubuntu 20.04**
>
> It is company policy to use only Ubuntu 20.04 on this computer. It is also company policy to use only the latest, official, stable Ubuntu 20.04 packages available for required software and services on this computer. Packages should be installed and managed by "apt". However, some packages may have been installed as a snap and should be reviewed for adherence to business policies.
>
> Midjiwan has decided that the default web browser for all users on this computer should be the latest stable version of Firefox.
>
> Company policy is to never let tribes log in as root. If administrators need to run commands as root, they are required to use the "sudo" command.
>
> The tribes have additionally agreed upon configuring secure boot, please add root as a superuser and set an encrypted password in the /etc/grub/40_custom file.
>
> This machine was configured with a Samba server. Please ensure that this service is kept updated and active. Midjiwan has requested that every authorized tribe be added as a Samba user, and a new share created for the Bardur battleplan (/home/bardur/battleplan). Secure the share and do not allow Imperius access at all costs.

In this example, it details what package sources should be specified. *(See section 8-Updating)* The default browser is also specified to be Firefox, and that it should be updated. Then, it specifies how samba should be set up. *(see 9-SMB/Samba shares)*

1.2 – Readme Critical Services

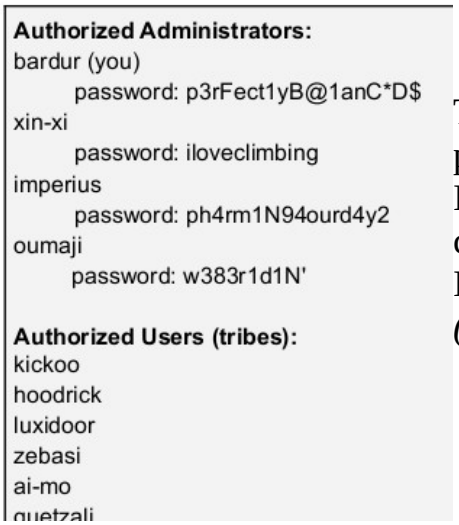
This section should be outlined in bold, and has services that need to be installed/running in point-form. For example, something like:



Other examples include:
SSH
Apache
FTP
etc…

This means that the service Samba must stay running at all times.

1.3 – Readme Users

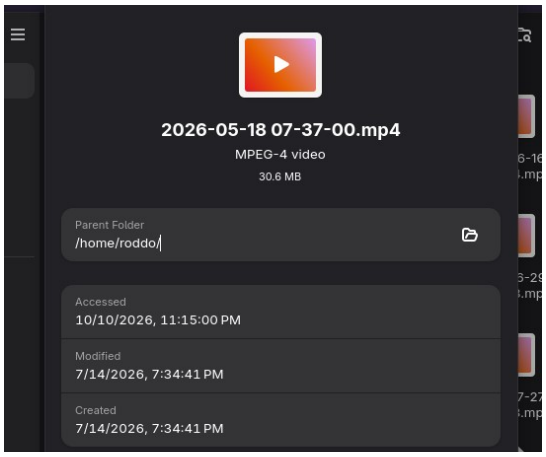


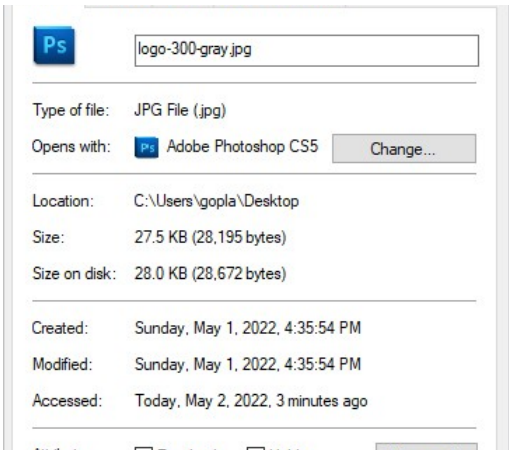
The README specifies a list of users and their passwords, first with Administrators then regular users. It is important to not change your own password as you could get locked out. *(Please see section 7-Users)*
It will look something like the example on the left. *(Passwords and usernames will vary!)*

2 – Forensic questions

After checking the **README** *(See 1-Readme 1.x)* please open the Forensic Question files found on your Desktop. They give an example question to show how it would be formatted, followed by the actual question. Said question changes depending on the scenario, but they usually involve one of the following:

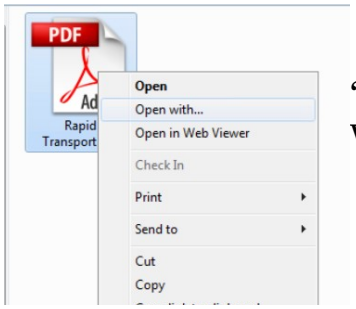
a) Finding an unauthorized file. *(check 5-Finding unwanted files)* You may have to provide the file path. Ex:





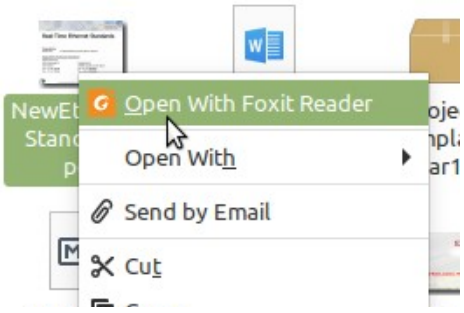
Linux has “Parent Folder” and Windows has “Location.” *They both mean the same thing.*
If it asks for the file **path**, add the name of the file to the location provided. Ex:
“/home/cooldude/” + “file.png” → “/home/cooldude/file.png”
If it asks for the **Parent folder**, simply provide the location folder in the Properties window.

b) Getting the contents of a file. For either Windows or Linux, you should Right-click then “Open with…” with Notepad (or Text Editor on Linux)



“Open with…” on Windows

...And on Linux



c) Getting the root of a WebServer (Windows/Server). To do this, use the IIS manager. *(Please see 13-Internet Information Services (IIS) Manager)*

d) Getting the hash of a file. *(To do this, please see 5-Finding unwanted files / Hashes)*

3 – Firewall

A firewall simply filters what connections can be made to a computer.

The following is for **Linux**
Under Linux, use the **`ufw`** Terminal command with **`enable`** or **`disable`** to enable/disable the firewall. This must be ran as root with **`sudo`** . Ex:

```
roddo@thinkpad-poupad:~$ sudo ufw enable
Password:
Firewall is active and enabled on system startup
roddo@thinkpad-poupad:~$
```

*If ufw is not installed, use **`sudo apt install ufw`** to install it.*

To check your UFW configuration, run **`sudo ufw status verbose`** . It should return the following:

```
Status: active
Logging: on (low)
Default: deny (incoming), allow (outgoing), disabled (routed)
New profiles: skip
```

The following is for **Windows**
Under Windows, start up the Control Panel with the start menu then click "**System and Security**," Then, click "**Windows Defender Firewall.**" Once you are at the interface shown below, enable " Use recommended settings" to get Windows to do all the work for you. Once the button is pressed, the firewall sections should turn green.
Ex.

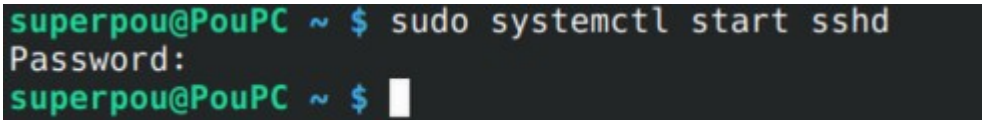


4 – SSH (Linux only)

SSH is the way people access machines across the network on Linux.

*Note: Please read the **readme** (1.2 – Readme Critical Services) to see if SSH is a required service.*

To enable ssh, use use the `systemctl` command.



To properly configure SSH, you must edit /etc/ssh/sshd_config . Most of these settings will likely be configured already, but we still need to check each one to make sure. If you add any lines, make sure they go *above* any Include or Match statements. Essentially, put them at the top of the file. When the settings are read, they work from top to bottom.

```
Protocol 2
Ciphers -3des-cbc,aes128-cbc,aes192-cbc,aes256-cbc,chacha20-
poly1305@openssh.com
ClientAliveInterval 15
ClientAliveCountMax 3
DisableForwarding yes
GSSAPIAuthentication no
HostbasedAuthentication no
IgnoreRhosts yes
KexAlgorithms -diffie-hellman-group1-sha1,diffie-hellman-group14-
sha1,diffie-hellman-group-exchange-sha1
LoginGraceTime 60
loglevel VERBOSE
MACs -hmac-md5,hmac-md5-96,hmac-ripemd160,hmac-sha1-
96,umac-64@openssh.com,hmac-md5-etm@openssh.com,hmac-md5-96-
etm@openssh.com,hmac-ripemd160-etm@openssh.com,hmac-sha1-96-
etm@openssh.com,umac-64-etm@openssh.com,umac-128-etm@openssh.com
MaxAuthTries 4
MaxSessions 10
MaxStartups 10:30:60
PermitEmptyPasswords no
PermitRootLogin no
PermitUserEnvironment no
UsePAM yes
```

After making any changes run the following:

```
systemctl restart sshd
```

This will restart the sshd service and apply any changes you have made.

5 – Finding unwanted files / Hashes

In *most* scenarios, you might have to look for a file to either anwser a Forensic question or to simply delete. The README will say if it permits non-work related files. *Please check to see if the forensic questions mention files you find before you delete it!*

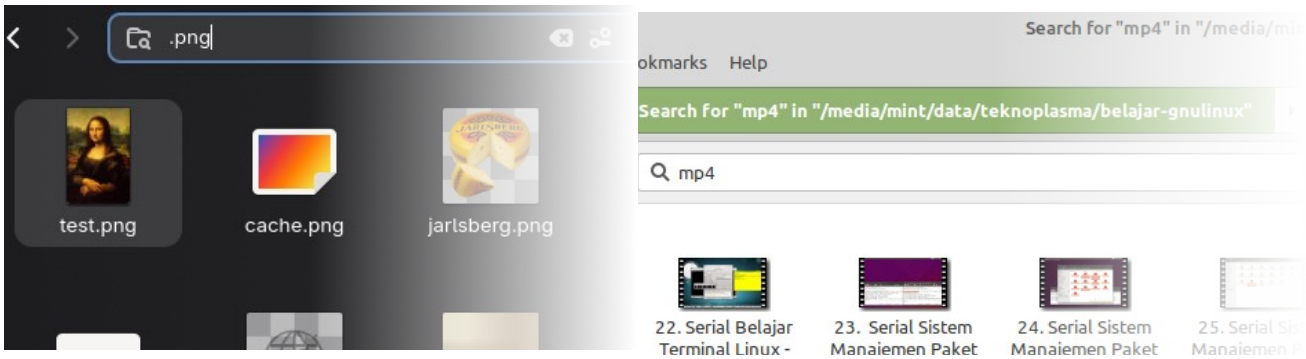
Common types of unwanted files are *(sorted by probability)*
.png .jpeg .jpg .mp4 .flac .wav .mov etc…

The following is for **Linux**
To find a specific file on **Linux**, you can do it one of two ways. Method one is to use the **`find`** command. Follow this skeleton to use it: **`find /home | grep "file"`** *Note: Linux seperates commands by spaces, so make sure to put your file in quotes if it contains spaces!* Ex:

```
roddo@thinkpad-poupad:~$ find /home | grep .png
/home/roddo/Examples_FLTK/src/Controls/Box_Picture2/Resources/Logo.png
/home/roddo/Examples_FLTK/docs/Pictures/Logo.png
/home/roddo/Examples_FLTK/docs/Pictures/Fltk.png
/home/roddo/Examples_FLTK/docs/Pictures/fltk_header.png
/home/roddo/Examples_FLTK/docs/Pictures/Examples/Password.png
/home/roddo/Examples_FLTK/docs/Pictures/Examples/Mouse_Events.png
/home/roddo/Examples_FLTK/docs/Pictures/Examples/Key_Events.png
```

(In my case, I have many image files on my personal computer.)

/home is the place you should be checking since all user data is stored there. To do this graphically, you can use your file manager. You should see "**Computer**," or "**File System**" on the left side of the window. Once you are there, navigate to /home and do a search there. *(it may look like a magnifying glass or a folder with a magnifying glass)*

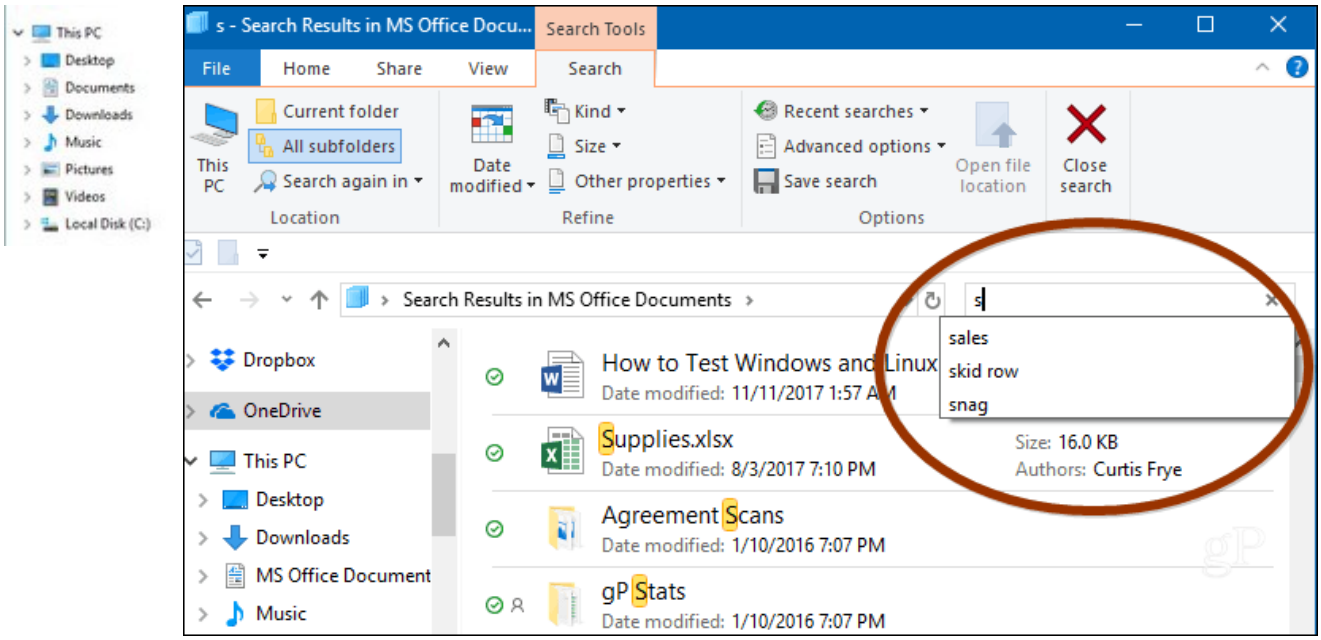


To get the hash of a file on **Linux**, you can use the following commands depending on what the forensic question specifies:

```
sha256sum filename
md5sum filename
sha1sum filename
sha512sum filename
```

All will output the specified hash followed by the filename.

The following is for **Windows**
Open up File Explorer, then navigate to Local Disk C: Under “This PC”, then to “Users”. You may now search for the prohibited files. *(prefixed with “*”!)* Ex:



You can also search for files using Powershell on Windows. Using Powershell, we can search for files a lot more quickly and smoothly than by using Explorer. This is often useful for Forensics questions, and allows you to do other work while it searches. The following code searches for a file called "example.html" in the C:\Users directory and all of its subdirectories. You can change the directory to just "C:\" in order to search the entire filesystem. You can also use wildcards (*) in the filename.

```
Get-ChildItem -Path C:\Users -Filter example.html -Recurse
-ErrorAction SilentlyContinue -Force
```

In Powershell, we can easily find the hash of a file using the following command:

```
Get-FileHash -Algorithm algorithm filepath
```

If the hash is asked for, it will specify what algorithm to use in the question.

6 – Removing unwanted programs

Note: Please check the Forensic questions to make sure they don't require any tools that would be removed here, such as Wireshark or npcap. The readme might also say that certain programs may not be removed. Also, some non-programs count such as Chrome/Firefox extensions.

An "unwanted program" is a program found on the virtual machine that gives points when removed.

The following is for **Linux**
Under Ubuntu/Linux Mint/debian, **`apt`** is the program that you use to remove/add programs. (*Or as Linux calls them, "packages")* apt **must** be ran with **`sudo`** . Example for removing programs:

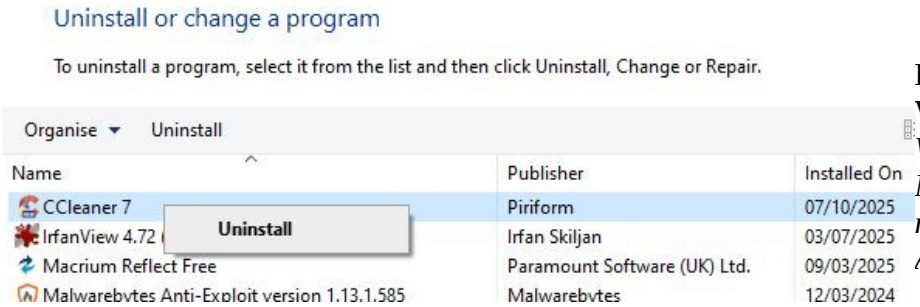
```
bash-5.0$ sudo apt remove wireshark
Reading package lists... Done
Building dependency tree
Reading state information... Done
```

Note: apt requires you to confirm before you remove/add. Type "y" then Enter to continue

List of unwanted software for **Linux**:
wireshark, nmap, ophcrack, john, wapiti, freeciv, postfix, p0f, netcat, vim
Unwanted games (Ubuntu):
aisleriot, five-or-more, four-in-a-row, gnome-2048, gnome-chess, gnome-klotski, gnome-mahjongg gnome-mines, gnome-nibbles, gnome-robots, gnome-sudoku, gnome-taquin, gnome-tetravex, hitori, iagno, lightsoff, quadrapassel, swell-foop, tali
Unneeded services **(only IF the readme does not mention them)**:
apache2, sshd, samba, ftpd/proftpd, mysql

The following is for **Windows**
Under **Windows/Server**, use the **Control Panel** to remove unwanted programs. First, click "**Uninstall a program**", then right-click on the program you want to remove and click "**Uninstall**."

Remember: never uninstall a program that is mentioned as required in the README. You also should not uninstall VMWare Tools, Microsoft Visual C++, or Microsoft .NET.



List of unwanted software for **Windows**:
Wireshark, CCleaner, Cursor, Npcap, Nmap, RainbowCrack, rustscan, qBittorent, Cain and Abel

Note that not all programs might show up in the Control Panel "**Programs and Features**." Some might be on the Desktop (Like CCleaner on some images) or hidden away. (like goose.exe)

It is a good idea to go through the C:\Users folders on **Windows** or the /home directories on **Linux** to check manually for any suspicious files.

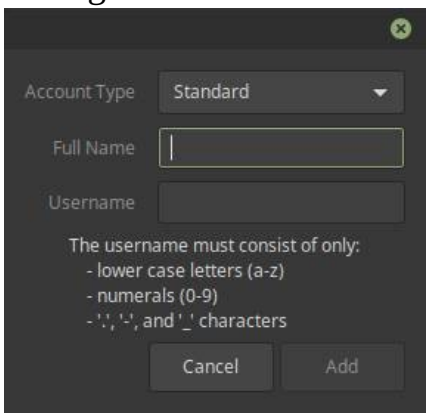
7 – Users & Groups

An easy way to get some points is to set up all the **Users**. *(see 1.3-Readme users to see what the list of users provided by the readme looks like)* This involves going to the **user management** for both **Linux** and **Windows** to ensure everyone has a **secure** password and that they are marked as either **administrator** or not. You should also check the **list** of users you see in the Control Panel/User Management against the readme to ensure **everyone** is accounted for. If a user is **missing**, add them. If a user is not supposed to be there, **remove** the account.
Please make sure the Forensic questions don't require them before removing!
If you do have to remove an account, make sure to keep their files in case you need them later.

The following is for **Linux**
Under **Linux Mint**, you need to open the **Start menu** and click the **Settings/Preferences** icon on the left. Click on "**Users and Groups**". You should be shown a window with the list of users on the left, and configuration for them on the right. From here, you can configure account type *(Administrator or Standard)* change Passwords, or remove users. Right click the user to bring up the configuration menu on the right. To add users to a group, click the "Groups" tab on the Users and Groups window to add/remove users from groups.

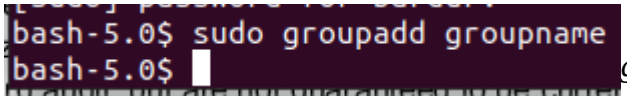


Configuration window:



*The principles are similar for **Ubuntu**, it is just the placement of buttons/inputs that changes.*

To create a new group on **Linux** *(If the README requires it)* use the **`groupadd`** command, it takes the group name as an argument *(shown below as "groupname").* It **must** be run with **`sudo`** . Once you have made a new group, you can add them in the settings window.

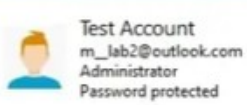


Replace "groupname" with the actual name of the group.

The following is for **Windows**
Under **Windows**, user configuration is done via the **Control Panel**. Open the control panel using the Start Menu and click "**User Accounts**." From here, you can double-click a user to change account type change passwords, or remove them. You can also add a new user.

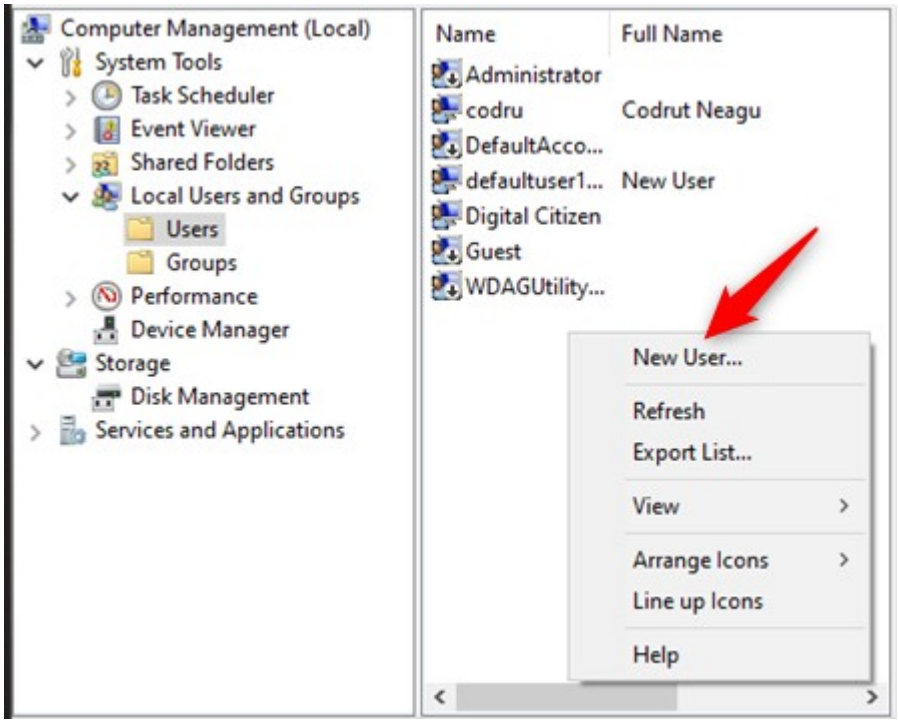






13

To create a new Group on **Windows**, you can use the Computer Management program. Once opened with the Start Menu, navigate to Computer Management (Local) → System Tools → Local Users and Groups . From here, you can add new users *(offers more control over the Control panel,)* create new groups and **add** users to said groups. You can click on the Users folder get a list of users, and the Groups folder to get a list of groups. **Right click** on the empty space to get a dialogue where you can add new Users/Groups.



8 – Updating

Note: Please check the readme to see if it mentions keeping programs updated. Common ones are Chrome, Firefox, LibreOffice, 7-zip, Notepad++, etc.
Note: Please only consider updating (especially on Linux) once you have done other less time-consuming tasks, as updating can take a while!

The following is for **Linux**
Under Linux **Mint/Ubuntu** you can update the system with the **`apt`** command. It must be ran with **`sudo`** . First, you must tell it to **`update`** the packages it can see.

```
bash-5.0$ sudo apt update
Hit:1 http://us.archive.ubuntu.com/ubuntu focal InRelease
Hit:2 http://us.archive.ubuntu.com/ubuntu focal-updates InRelease
Hit:3 http://us.archive.ubuntu.com/ubuntu focal-backports InRelease
Reading package lists... Done
Building dependency tree
Reading state information... Done
450 packages can be upgraded. Run 'apt list --upgradable' to see them.
```

*You should see some packages that can be upgraded. In this case, this virtual machine should **REALLY ONLY** be updated near the end. **450 packages will take some time!***

Then, you should commence the actual update process with **`sudo apt upgrade`** .

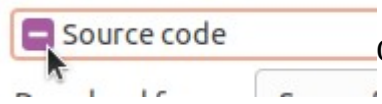
```
bash-5.0$ sudo apt upgrade
Reading package lists... Done
Building dependency tree
Reading state information... Done
Calculating upgrade... Done
The following package was automatically installed and is no longer required:
  gir1.2-goa-1.0
Use 'sudo apt autoremove' to remove it.

Enable UA Infra: ESM to receive additional future security updates.
See https://ubuntu.com/20-04 or run: sudo ua status
```

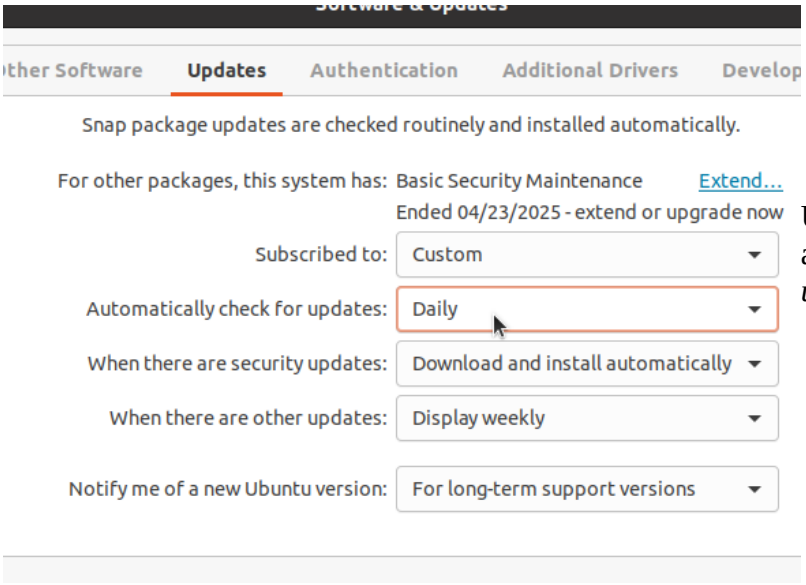
It will spew out all the packages that can be upgraded. Type "y" then Enter to proceed.

Ubuntu and **Linux Mint** both have something called "**Software & Updates**." From here, you can configure when the system updates and what packages it can use. To open this program, search "**Software & Updates**" in the Linux Mint start menu or the Ubuntu Apps menu.

The README should say what sources should be enabled and what frequency to update here.

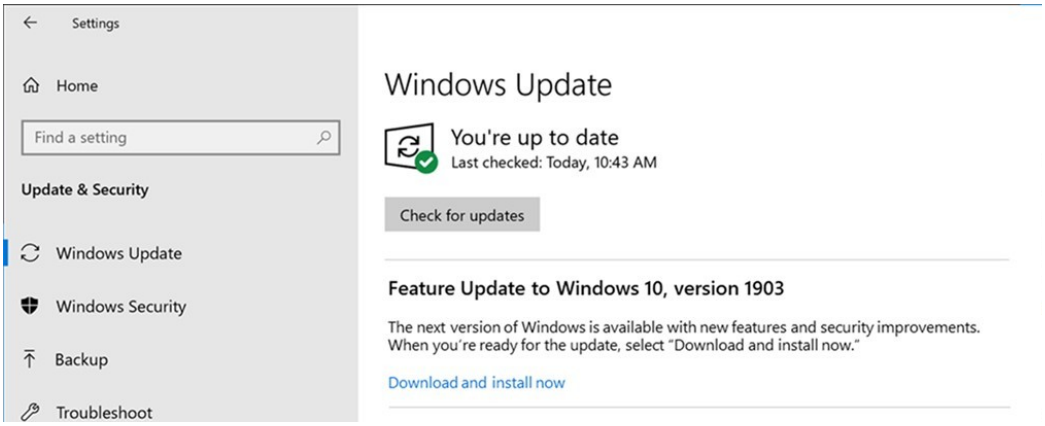


Once opened, check "**Source Code**" under "**Ubuntu Software**."



Under "**Updates**," make sure it automatically checks for updates **Daily**, *unless the README says otherwise.*

The following is for **Windows**
To update **Windows**, go to the Start Menu and open Settings on the left, or type in "**Settings**" and open the program. Navigate to **Windows Update** and check/install available updates. This will take a while, and it will slow down the computer the whole time. **Don't do it right at the start**, but don't wait too long either. I recommend letting these run as you eat lunch, or something similar.



If using Google Chrome, the README will no doubt tell you to keep it up-to-date. To ensure this, open Google Chrome and enter **`about:policies`** into the navigation bar, then hit Enter. From here, enable "Automatic Updates."

Other software is much tougher. For example, to update 7-zip, Notepad++ or Libreoffice, you must ask your team leader for a USB drive that has the newer version's installer for whatever software on them. This is because the computers on the network have strict filters and have trouble connecting to modern websites.

9 – SMB/Samba shares

The Server Message Block protocol, often called SMB, is a protocol used to share files, share printers, and communicate between processes. It is currently developed by Microsoft, though Samba allows **Linux** computers to use it as well. *Note: Please **only** enable SMB/Samba if the README requires it!*

The following is for **Linux**
Under Linux, you can start the **SMB** service using the **`systemctl`** command, like so:

```
bash-5.0$ sudo systemctl start smbd
bash-5.0$
```

*The reason many services on **Linux** end with "d" is because services on Linux are called Daemons, so smbd means Samba Daemon.*

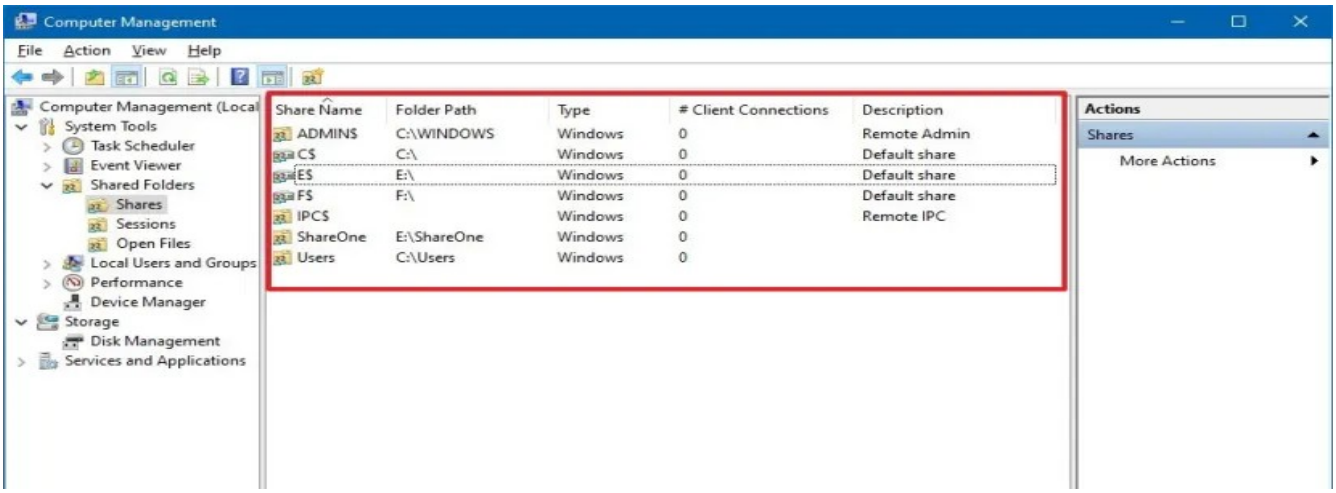
The configuration files for SMB are located at **/etc/samba/smb.conf** .

The following is for **Windows**
Using SMB1, the earliest version of SMB, is very risky. It is best to disable it and only use SMB2 or SMB3. In order to do so, you can use the following P**owershell** command:

```
Disable-WindowsOptionalFeature -Online -FeatureName SMB1Protocol
```

Take note that this **will restart** the computer, so make sure you're not in the middle of anything else!

Some README scenarios or forensic questions may ask about SMB Network Shares. To view/manage network shares, start the **Computer Management** application by going to the **Start Menu** and typing "**compmgmt.msc**", then open the "**Computer Management**" application.



From here, you can add and remove shares. The three defaults are IPC$, C$, and ADMIN$. These do not need to be removed. All others, unless specified in the README, can be removed. Shares with a '$' in them are hidden, and cannot be seen using usual means. They are still accessible, though, and need to be removed just the same.

Enabling SMB signing is very important for security. If somebody tampers with an SMB message while it is in transit, the signing can help your computer notice that something is wrong. This prevents vulnerability to "Man-in-the-Middle" attacks.

In gpedit.msc, go to: Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options and set "Microsoft network client: Digitally sign communications (always)" to enabled. Or, in Powershell, run:

```
Set-SmbClientConfiguration -RequireSecuritySignature $true
```

Authentication Rate Limiter

The authentication rate limiter in SMB does exactly as it says on the tin. It limits how often authentication attempts can be made. This will greatly slow down any brute-force attacks attempted on your system. The timeout should be set short enough that is does not affect regular use.

PowerShell

You can use the following command to set the timeout length in PowerShell:

```
Set-SmbServerConfiguration -InvalidAuthenticationDelayTimeInMs 2000
```

That example sets it to 2000 milliseconds (2 seconds), but it can be set to any multiple of 100 within 0 and 10'000.

Group Policy Editor

It can also be set using the Group Policy Editor at this location:

Computer Configuration\Administrative Templates\Network\Lanman Server

Set "Enable authentication rate limiter" to Enabled.

Note that you cannot set the delay time using the Group Policy Editor. It can only be changed in PowerShell.

Encryption

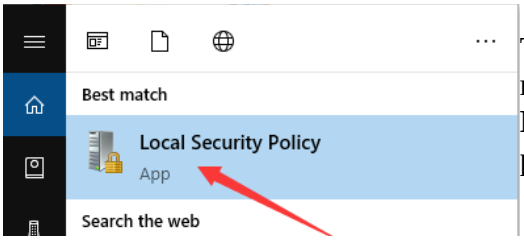
Encrytpting SMB messages is important for preventing third parties from snooping on what files are being accessed and the contents of those files.

Use the following command to enable encryption on compatible SMB servers:

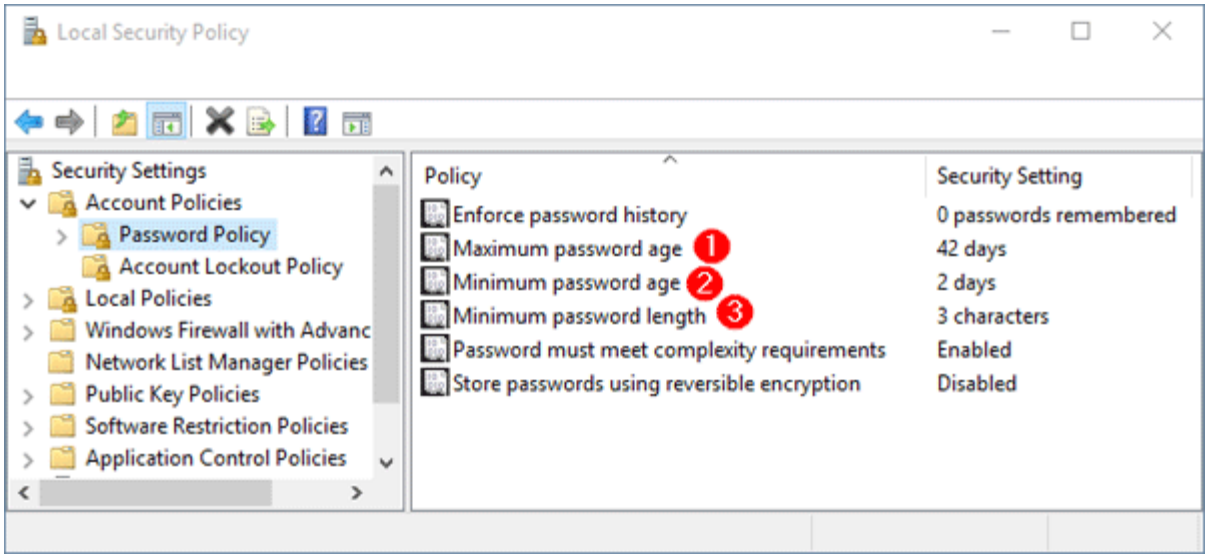
```
Set-SmbServerConfiguration –EncryptData $true
```

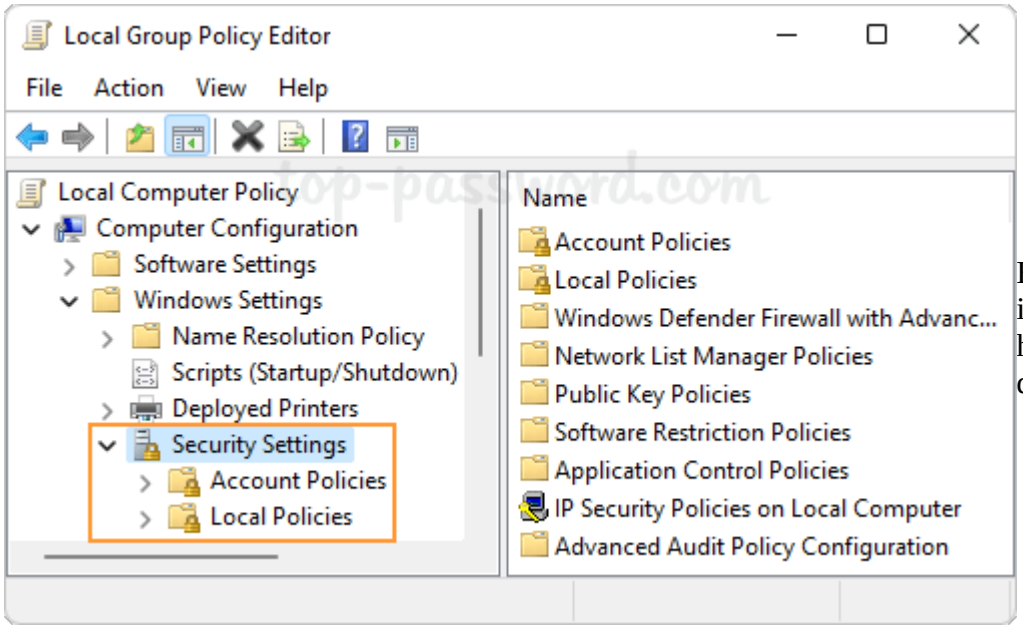
10 – Local Security Policy (**Windows** only)

Note: Please check the readme to see if certain password policies are specified



The **Local Security Policy** is where you will be configuring most of **Windows**. You can run it by typing "**Local Security Policy**" into the **Start Menu**, then clicking the reccomended program.





Everything is organized in a file-like view hidden under dropdowns.

The next few pages will be a long list of policies to change. Policies with a ★ (• Example ★) are ones that have been scored vulnerabilities in the past. If you're in a rush, focus on these first.

Account Policies

The policies in the Account Policies branch of secpol relate to password requirements and locking accounts after failed sign-ins.

Password Policies

Included here are the policies defining password requirements. In order, these are:

- Enforce Password History ★

  Recommended: 24
  This is the number of previous passwords to save, in order to prevent users from rotating between a small number of passwords when asked to change them.

- Maximum Password Age ★

  Recommended: 90
  This number, in days, is how long a user can keep the same password before being forced to change it. These prevents old, potentially compromised passwords from remaining on the system.

- Minimum Password Age ★

  Recommended: 30
  This number, in days, is how long after changing a password before a user can change it again.

- Minimum Password Length ★

  Recommended: 14
  This is the minimum number of characters that a valid password can be. 14, for historical reasons, is the maximum on windows machines. It's also a good length for us.

- Password Must Meet Complexity Requirements ★

  Recommended: Enabled
  Without this enabled, none of the other password requirements take effect. They're not much use to us unless they're turned on, so make sure to enable this.

- Store Passwords Using Reversible Encryption ★

  Recommended: Disabled
  Windows already stores the passwords encrypted by default. This makes that encryption reversible, meaning that passwords can be learned just by finding them and unencrypting them. Usually, they're stored using unreversible encryption, so enabling this is a security risk.

Account Lockout Policy

These three policies dictate what should happen after consecutive failed login attempts:

- Account Lockout Duration ★

  Recommended: 30
  This number, in minutes, is how long the account should be locked out once enough failed logins occur.

- Account Lockout Threshold ★

  Recommended: 5
  This is how many failed attempts are needed to trigger the account lockout. It shouldn't be too low, otherwise a series of honest typos could trigger it. It also shouldn't be too high, or it'll give malicious actors more attempts to crack the password. 5 is a good middle-ground.

- Reset Account Lockout Counter After ★

  Recommended: 30
  This is how many minutes it takes for the failed login attempt counter to reset.

Local Policies

The Local Policies branch is much more varied, containing the Audit Policy, User Rights Assignment, and Security Options nodes.

Audit Policy

The Audit Policy is by far the simplest of the three. All you need to do is go into every option and check success and failure.

These options decide whether the computer keeps a log of administrative and other actions performed on it. How on earth you read them is beyond me, though.

User Rights Assignment

Here, we control which users are allowed to do what. Each setting can be set to a list of either users or groups. The recommended settings show the list of users or groups, separated by a comma and a space.

- Access Credential Manager as a trusted caller

Recommended: No-one
This setting is only used by Credential Manager when backing up and restoring systems. No users should have this permission, as it could allow them to access other user's credentials.

- Access this computer from the network ★

  Recommended: Administrators, Remote Desktop Users
  It's good to make sure only trusted users are allowed to access the computer remotely. This reduces the attack surface of the computer and gives fewer opportunities to malicious actors.

- Act as part of the operating system

  Recommended: No-one
  Anyone with this right can completely control the computer and even erase any trace of their activities. It is incredibly hazardous to give to people, and should not be used.

- Adlust memory quotas for a process

  Recommended: Administrators, LOCAL SERVICE, NETWORK SERVICE
  This permission allows a user to adjust how much memory is available to a process. This can by very useful for fine-tuning systems, but in the wrong hands could lead to denial-of-service.

- Allow log on locally

  Recommended: Administrators, Users
  This controls who can login to the computer from the console. Illegitimate users, if given this permission, could login and use malware to elevate their privileges. If legitimate users are not allowed to login, then the computer will be of little use to anybody.

- Allow log on through Remote Desktop Services

  Recommended: Administrators, Remote Desktop Users

- Back up files and directories

  Recommended: Administrators

- **Bypass traverse checking**

  Recommended: No One

- Change the system time

  Recommended: Administrators, LOCAL SERVICE

- Change the time zone

  Recommended:Administrators, LOCAL SERVICE, Users

- Create a pagefile

  Recommended: Administrators

- Create a token object

  Recommended: No-one

- Create global objects

  Recommended:Administrators, LOCAL SERVICE, NETWORK SERVICE, SERVICE

- Create permanent shared objects

  Recommended: No-one

- Create symbolic links

  Recommended: Administrators

- Debug programs

  Recommended: Administrators

- Deny access to this computer to from the network

  Recommended: Guests, Local Account

- Deny log on as a batch job

  Recommended: Guests

- Deny log on as a service

  Recommended: Guests

- Deny log on locally

  Recommended: Guests

- Deny log on through remote desktop services

  Recommended: Guests

- Enable computer and user accounts to be trusted for delegation

  Recommended: No-one

- Force shutdown from a remote system ★

  Recommended: Administrators

- Generate security audits

  Recommended: LOCAL SERVICE, NETWORK SERVICE

- Impersonate a client after authentication

  Recommended: Administrators, LOCAL SERVICE, NETWORK SERVICE, SERVICE

- Increase scheduling priority

  Recommended: Administrators, Window Manager\Window Manager Group

- Load and unload device drivers

  Recommended: Administrators

- Lock pages in memory

  Recommended: No-one

- Log on as batch job

  Recommended: Administrators

- Log on as service

  Recommended: WDAGUtilityAccount

- Manage auditing and security log

  Recommended: Administrators

- Modify an object label

  Recommended: No-one

- Modify firmware environment labels

  Recommended: Administrators

- Perform volume maintenance tasks

  Recommended: Administrators

- Profile single process

  Recommended: Administrators

- Profile system performance

  Recommended: Administrators, NT SERVICE\WdiServiceHost

- Replace a process level token

  Recommended: LOCAL SERVICE, NETWORK SEVICE

- Restore files and directories

  Recommended: Administrators

- Shut down the system

  Recommended: Administrators, Users

- Take ownership of files or other objects

  Recommended: Administrators

Security Options

- Prevent users from installing printer drivers ★

  Recommended: Enabled

- Prevent CD-ROM access ★

  Recommended: Enabled

- Do not allow anonymous enumeration of SAM accounts ★

  Recommended: Enabled

- Do not allow anonymous enumeration of SAM accounts and shares ★

  Recommended: Enabled

- Name pipes that can be accessed remotely ★

  Recommended: Disabled

Accounts

- Limit local account use of blank passwords to console logon only ★

  Recommended: Enabled

Interactive Logon

- Do not require CTRL+ALT+DEL ★

  Recommended: Disabled

- Don't display username at sign-in

  Recommended: Enabled

11 – Roles and Features (**Windows** only)

The following is for **Windows** (*Though some parts are more **Windows Server** focused.)*
Roles define what type of server Windows computers are. This includes things like HTML webservers, file share servers, or domain controllers managing other computers on the network.

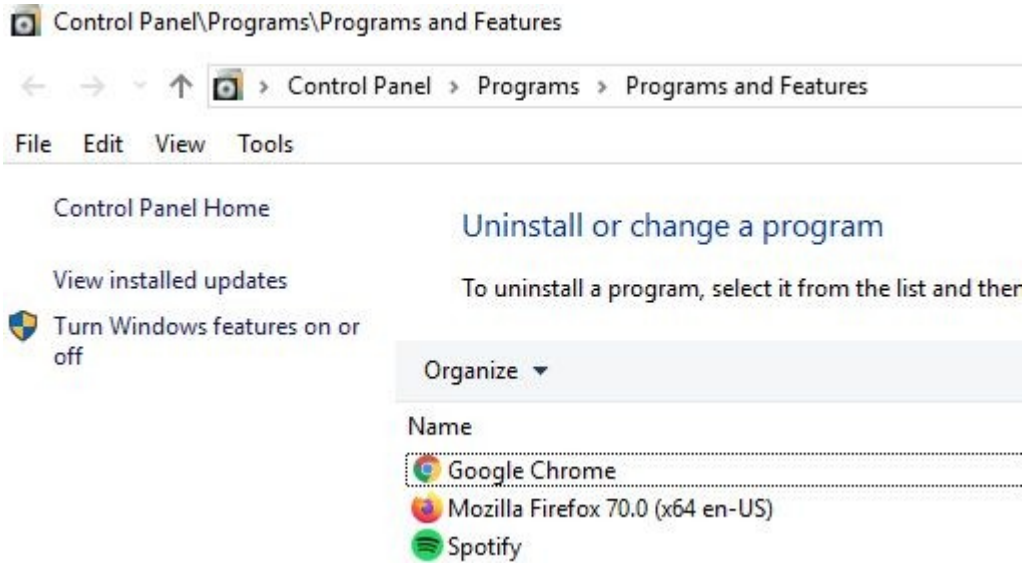
Features are generally a bit smaller than roles. They work as little bonus pieces of functionality for the computer. For example, BitLocker drive encryption is a feature. It works in addition to any other roles and features the computer has and doesn't completely change its function.

Sometimes there will be roles and features installed on a computer that do not need to be installed. These can present a security risk. The more unnecessary features on a computer, the more likely it is that at least one will have a security vulnerability.

Besides being a security risk, extra roles and features running in the background can slow down the computer. In a competition, this is annoying; in a real work environment, this could lead to loss of productivity or past work.

Adding / Removing Roles and Features

Adding and removing roles and features is slightly different between Server and workstation Windows. On regular Windows, you want to open "appwiz.cpl" in the run dialogue or find it in control panel.



The Add / Remove features button in Control Panel

On Windows Server, they can be managed in the Server Manager window. Click on the "Manage" tab in the top-right, then on "Add/Remove Roles and Features". From there, follow the prompts on-screen.

Roles to disable

All of them. Unless explicitly stated in the README, it shouldn't be there. Things like Telnet or FTP are common to see, and should always be removed (unless specified) due to security flaws.

Features to Disable

Remember: the README takes priority over all instructions here. If the README says to keep it, you keep it.

- Active Directory Services
- Internet Information Services
- Internet Information Services Hostable Web Core
- Media Features
- Print and Document Services
- RIP Listener
- Simple TCP/IP
- SMB
- SNMP
- Telnet
- Work Folders
- XPS Services

12 – Group Policy (**Windows** only)

The Group Policy Editor (gpedit.msc) is where most of the actual configuration happens on **Windows** computers. In here, you can manage near-on every aspect of the computer. From auditing to **Windows** Update, there's an endless array of options to edit. Best part, they're all organized in a handy directory tree, just like files.

Control Panel

- Personalization/Enable screen saver

  Recommended: Enabled

Network

- Network Connections/Windows Firewall

  Recommended: For all profiles, set "Windows Firewall: Protect all network connections" to Enabled

Windows Components

- Autoplay Policies/Turn off Autoplay

  Recommended: Enabled for all drives
  This is the rationale blurb.

- Remote Desktop Services/Remote Desktop Session Host/Connections/Allow user to connect remotely using Remote Desktop Services

  Recommended: Disabled
  You should not allow remote access to your computer. It is a security risk.

- Remote Desktop Services/Remote Desktop Session Host/Security/Require secure RPC communication

  Recommended: Enabled
  Only if RDP is enabled.

- Remote Desktop Services/Remote Desktop Session Host/Security/Require user authentication for remote connections by using Network Level Authentication

  Recommended: Enabled
  Only if RDP is enabled.

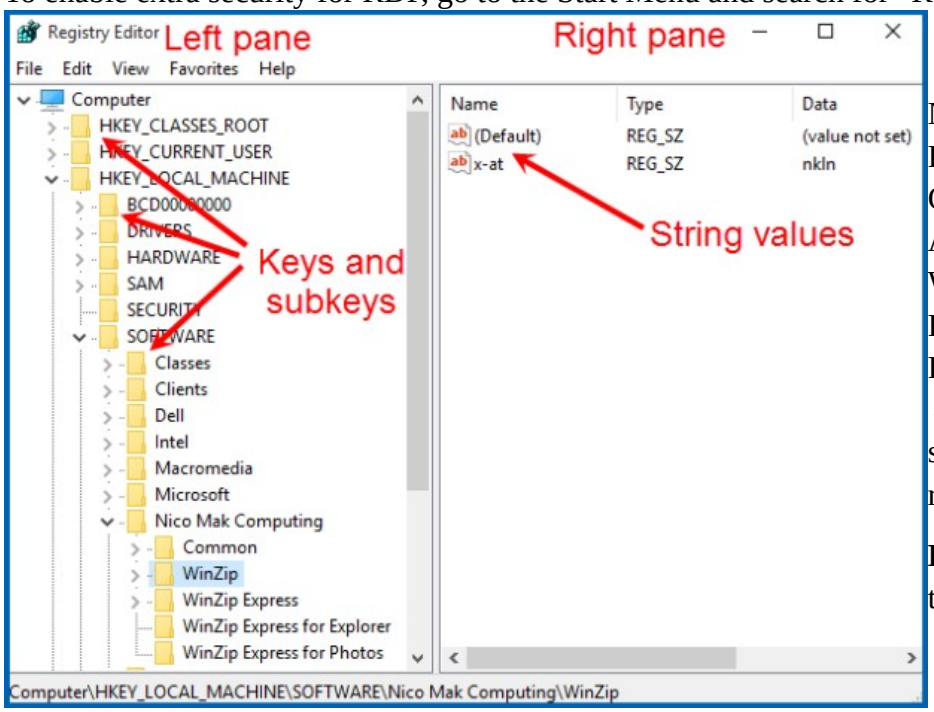
- Search/Allow Cortana

  Recommended: Disabled
  Annoying, unecessary, and probably insecure somehow.

13 – Remote Desktop Protocol (**Windows** only)

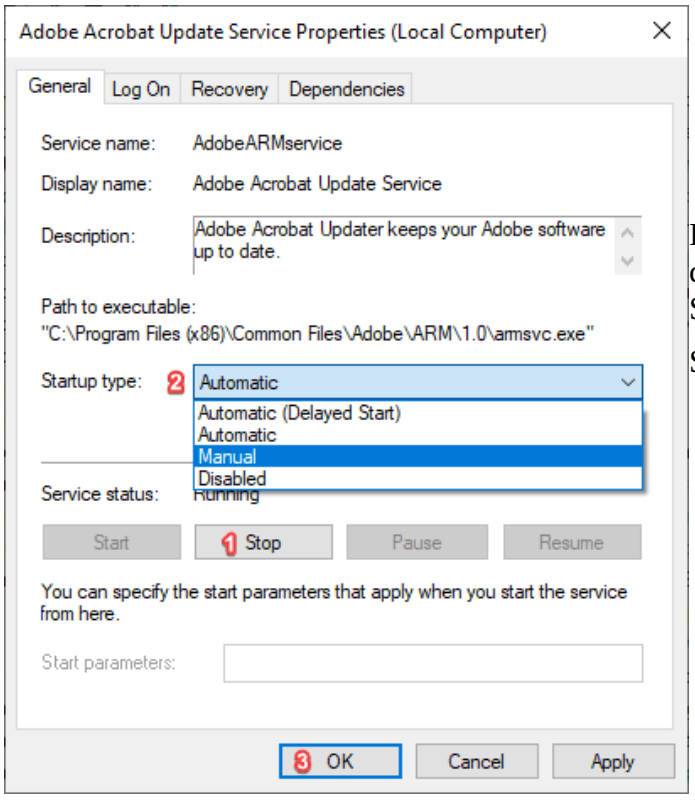
This should **only** be enabled if Remote Desktop Protocol is required via the README. To enable RDP, open the start menu then search Control Panel, then in the top-right search “Remote Desktop” and then enable it.

To enable extra security for RDP, go to the Start Menu and search for “Registry Editor.”



Navigate to: Local Computer Policy → Computer Configuration → Administrative Templates → Windows Components → Remote Desktop Services → Remote Desktop Session Host → Security → Require use of specific security layer for remote (RDP) connections

Enable, and set security layer to SSL



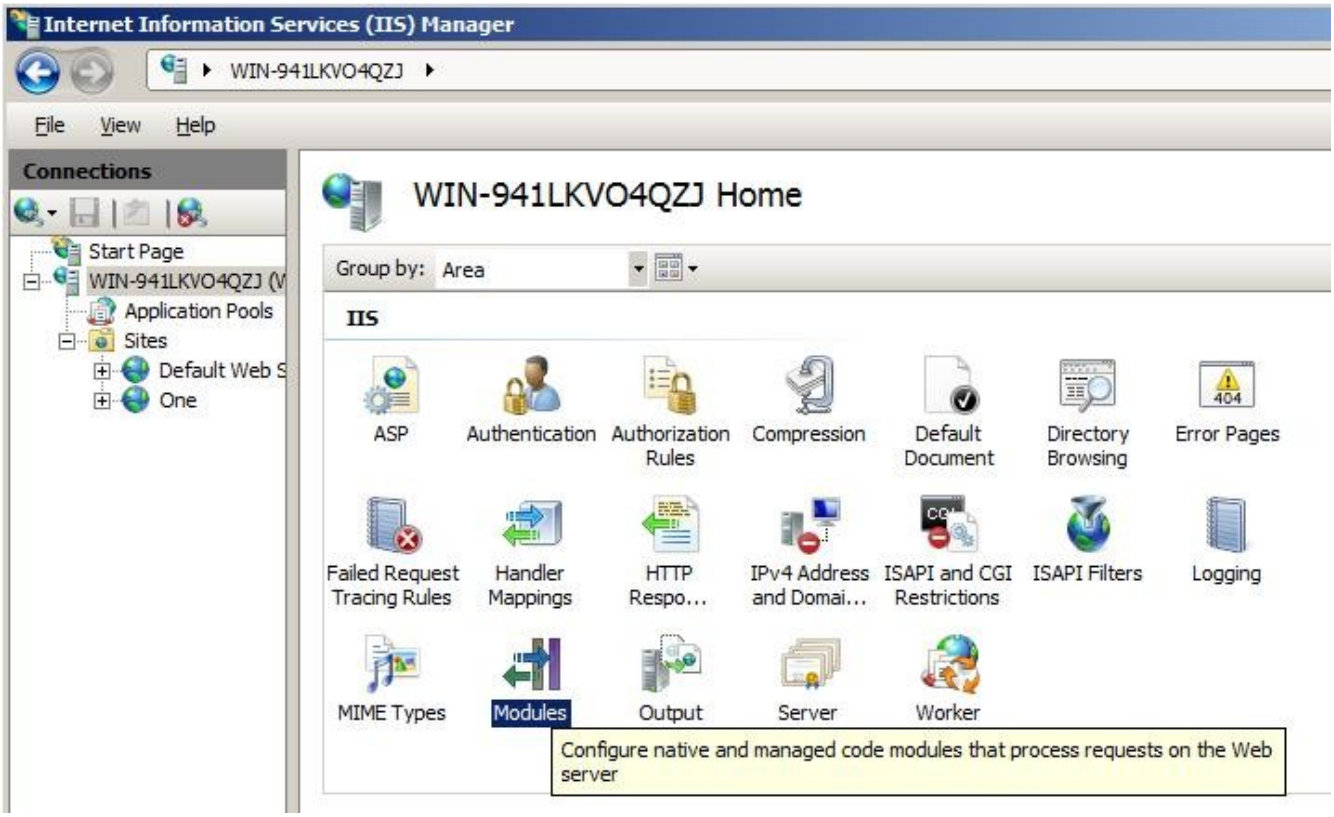
If the README does **not** mention RDP, hten you can disable it in the Services program. Open the Start Menu and search “Services” then open it.

Set the following to disabled:

- Remote Access Connection Manager
- Remote Desktop Configuration
- Remote Desktop Services

14 – Internet Information Services (IIS) Manager (**Windows Server** only)

This is where you can **manage** the network server on **Windows Server**. *This can be used to find the awnser for forensic questions, like finding the location of a network folder.* To open IISM, go to the Start Menu and type “inetmgr” then open it. It should open a window with a bunch of tools and a tree on the left, similar to the Local Security Policy.



Drop down on the left pane until you get to the website, “**Default Web Site**.” From here, you should be able to find the folder by clicking the “**Directory Browsing**” or right-clicking the **Default Web Site** and going to properties.

You can find the answer to many a forensic question using this helpful tool. *(Thank you to Danica for finding this one out!)*

15 – Cron (**Linux** only)

Cron is the tool on all **Linuxes** that starts programs at certain times. It does this with the **`crond`** service, which uses **/etc/crontab** . This has its uses but can often be used to do **remote attacks**. If the README/Forensic questions ask about a backdoor starting then this is a good place to look.

If you see any suspicious files here *(such as .py python files, or ones not shown below)* Then note it in any questions and remove them. *(Some forensic questions may **ask** for info about the file shown in the crontab, so **don't** remove it before taking note!)*

```
# Example of job definition:
# .---------------- minute (0 - 59)
# |  .------------- hour (0 - 23)
# |  |  .---------- day of month (1 - 31)
# |  |  |  .------- month (1 - 12) OR jan,feb,mar,apr ...
# |  |  |  |  .---- day of week (0 - 6) (Sunday=0 or 7) OR sun,mon,tue,wed,thu,fri,sat
# |  |  |  |  |
# *  *  *  *  * user-name command to be executed
17 *    * * *   root    cd / && run-parts --report /etc/cron.hourly
25 6    * * *   root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.daily )
47 6    * * 7   root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.weekly )
52 6    1 * *   root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.monthly )
```

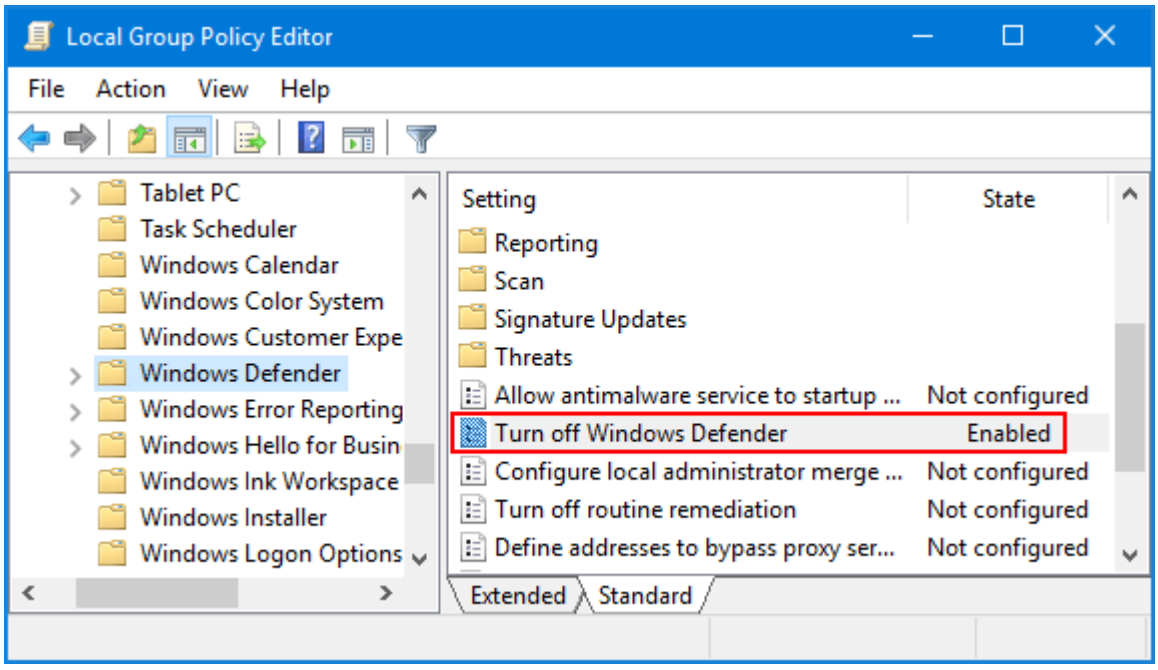
To start the cron service, use the **`systemctl`** command with **`sudo`** .

```
bash-5.0$ sudo systemctl start cron
bash-5.0$
```

Cron also has various folders that work the same as the entries in **/etc/crontab** . **/etc/cron.d** , **/etc/cron.daily** , **/etc/cron.weekly** and **/etc/cron.monthly** . Each executable in these is ran according to the folder's date text. *(Ex. Monthly is ran every month)* And, **/var/spool/cron/crontabs** is a lesser-known crontab location for printers, which is a good place to check just in case.

16 – Windows Defender (**Windows** only)

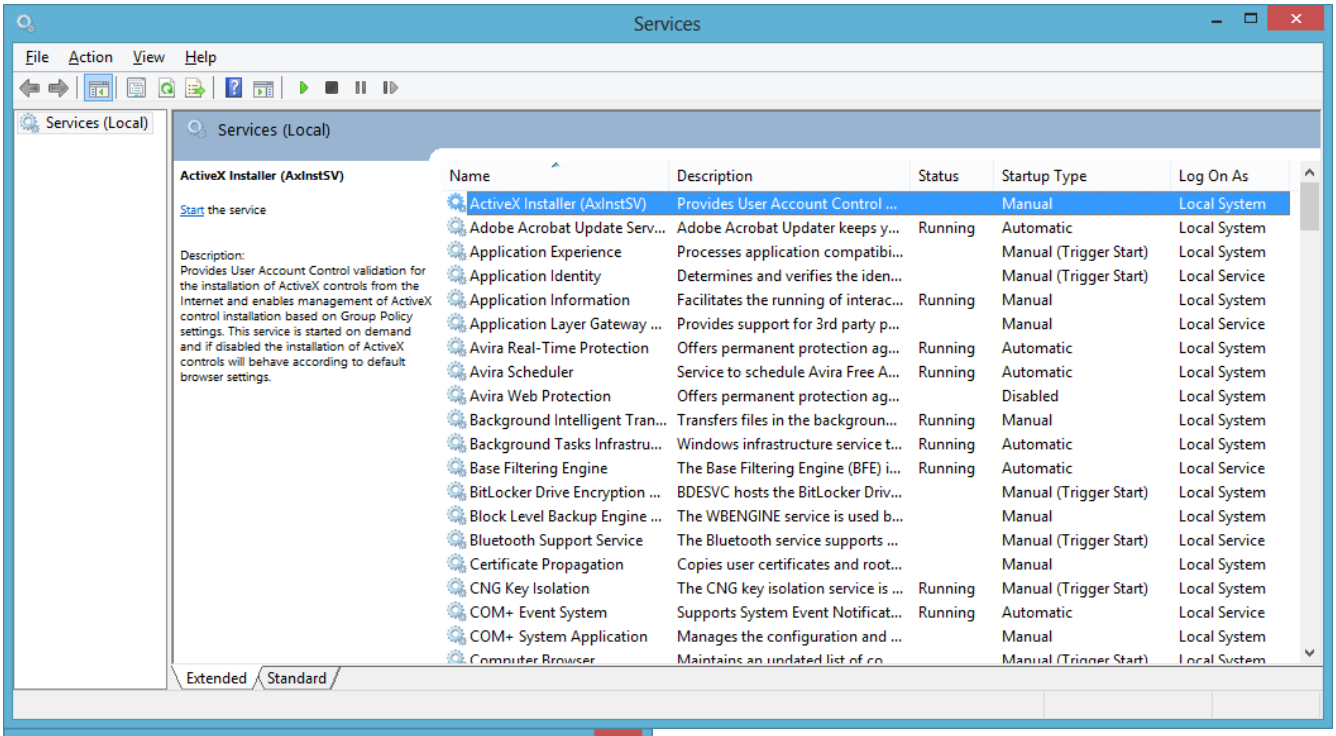
Some **Windows** images require **Windows Defender** to be enabled. To do this, you can use the Local Group Policy Editor. Open the start menu and type “gpedit.msc”, Local Group Policy Editor should pop up. In the newly opened window, navigate to:
Local Computer Policy → Computer Configuration → Windows Settings → Administrative Templates → Windows Components → Windows Defender
disable “Turn off Windows Defender” *(Confusing, I know)*

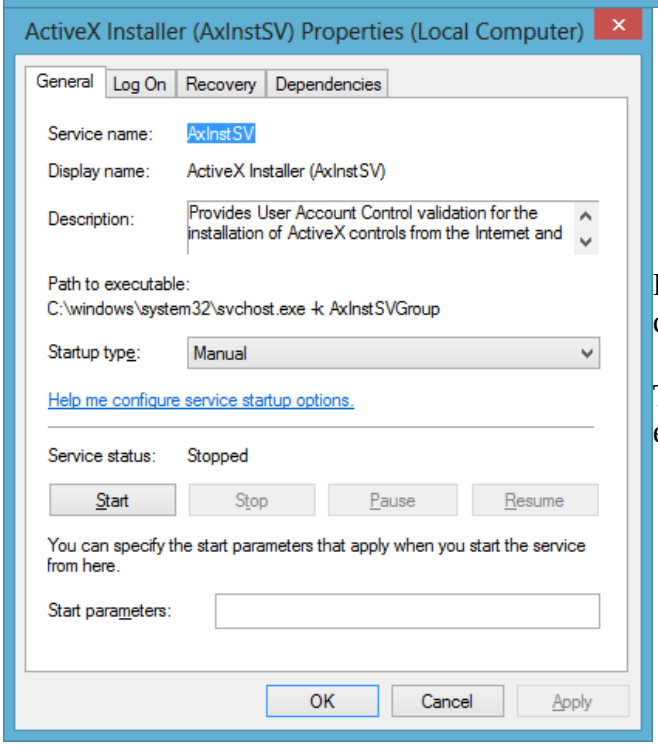


The location might change a bit depending on configuration/Windows version.

17 – Windows Services (**Windows** only)

Certain scenarios require you to make sure a **service** is running or stopped. To open the services window, type "**services.msc**" into the Start Menu and open it. It should look like this:





Right click on a service and go to Properties to change Startup type, or to start/stop the service.

The Properties menu also shows the Path to the executable.

Services to Disable

- *ActiveX Installer*
- *Adaptive Brightness*
- *Application Layer Gateway Service*
- *Bluetooth Support Service*
- *Certificate Propogation*
- *Fax*
- *NetMeeting Remote Desktop Sharing - VoIP*
- *Parental Controls*
- *Plug and Play*
- *Print Spooler*
- *Remote Registry*
- *RIP Listener*
- *Routing and Remote Access*
- *Simple File Sharing*
- *SNMP Trap*
- *SSD Discovery Service*
- *SSDP Discovery*
- *TCP/IP NetBIOS Helper*
- *Telephony*
- *Universal Plug and Play Device Host*
- *UPnP Device Host*
- *Windows Messenger Service*

Services to Enable *(If README deoes not specify. Otherwise disable. For exampl,e the README will put "ftp" under Critical Services. Enable that. If it does not mention Telnet, then disable it.)*

- *Microsoft FTP Service*
- *FTP*
- *Remote Desktop Help Session Manager*
- *Remote Desktop Configuration*
- *Remote Desktop Services UserMode*
- *Server* ***(do not disable on Windows server)***
- *Telnet*
- *Event log*

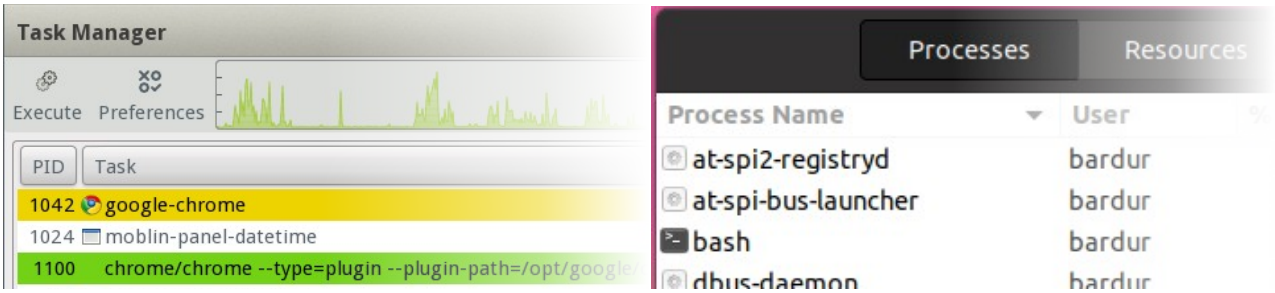
Also make sure to enable any services listed in the README.

18 – Listing programs

Weither for forensic questions or just to check on something, it can be useful to have a readout of everything running on the system.

The following is for **Linux**

There are a multitude of ways to view all running programs on **Linux**, some more readable than others. The most easy way to view processes is using the **System Monitor** on **Ubuntu** (run by opening the apps menu in the bottom-left and clicking the heart-rate looking monitor), or the **Task Manager** in **Linux Mint** (search in the Start Menu in the bottom left)

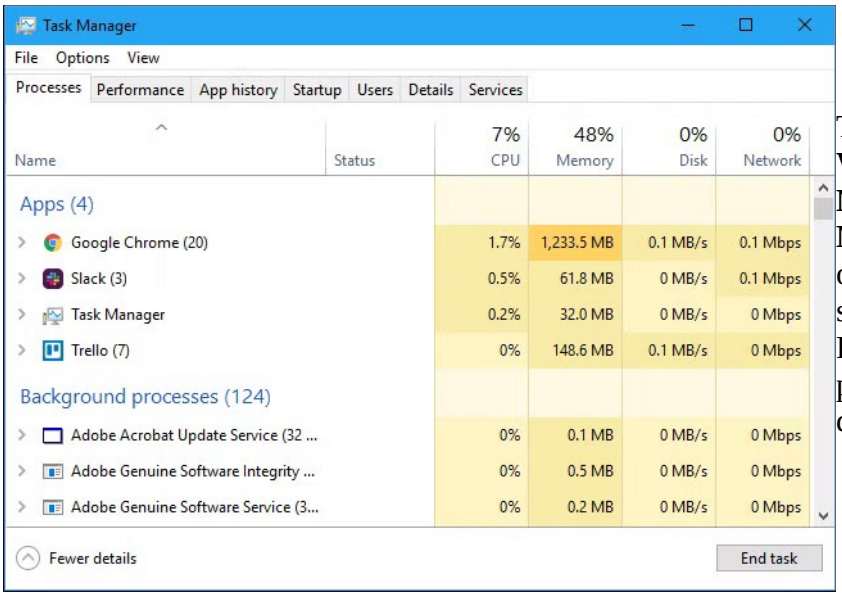


If you would prefer to use the Terminal to see all programs, first open the Terminal then use one of two commands:

the **`top`** command, which shows an interactive list of all running programs. *(press "q" to quit)*

The **`ps -xa`** command, which spits out all running programs into the terminal.

The following is for **Windows**



To view all running programs on **Windows** you can use the **Task Manager**. To open it, type "**Task Manager**" into the start menu then open what comes up. It will look something like this:

From here, you can **right click** any program and view where it is on the disk, or kill it with "**End task**."

Inside of task manager on the "**Startup**" tab, you can check to see what programs auto-start on boot. If there is anything suspicious, you may want to investigate.

19 – Ports

Some Forensic questions might ask you to get the port of a running process. On both **Linux** and **Windows**, you can use the **`netstat`** command to view all open ports. To see internet ports, use the **`-tulpn`** option(s). **`netsat`** has a ton of options. To view them, use **`netstat -h`** on Linux, or **`netstat /h`** on Windows.

```
bash-5.0$ netstat -tulpn
(Not all processes could be identified, non-owned process info
 will not be shown, you would have to be root to see it all.)
Active Internet connections (only servers)
Proto Recv-Q Send-Q Local Address           Foreign Address         State       PID/Program name
tcp        0      0 127.0.0.1:631           0.0.0.0:*               LISTEN      -
tcp        0      0 127.0.0.1:33060         0.0.0.0:*               LISTEN      -
```

*On Windows, use the **Command Prompt**. (Search **cmd.exe** in the **Start Menu** then open)*

```
C:\>netstat

Active Connections

  Proto  Local Address          Foreign Address        State
  TCP    127.0.0.1:58224        [redacted]:58247       ESTABLISHED
  TCP    127.0.0.1:58226        [redacted]:58246       ESTABLISHED
  TCP    127.0.0.1:58246        [redacted]:58226       ESTABLISHED
```

20 – Pam/General Security

The following is for **Linux**
In **/etc/security/faillock.conf**, add or edit the following lines:

```
deny = 5
unlock_time = 900
root_unlock_time = 60
```

For pam_pwquality, there is a hierarchy to which settings take priority. Module arguments in the common-* files override settings in **/etc/security/pwquality.conf** . Settings in files in **/etc/security/pwquality.conf.d/** are overridden by either. It is recommended by the CIS to use a *.conf file in **/etc/security/pwquality.conf.d/** for "clarity, convenience, and durability."

Include the following lines in **/etc/security/pwquality.conf** :

```
difok = 2
minlen = 14
minclass = 0
dcredit = 0
ucredit = 0
ocredit = 0
lcredit = 0
maxrepeat = 3
maxsequence = 3
enforce_for_root
```

The following is for **/etc/login.defs**
PASS_MAX_DAYS should be **130**
PASS_MIN_DAYS should be **30**
PASS_WARN_AGE should be **0**

/etc/shadow should not be world readable. Run **`chmod 600 /etc/shadow`**

The following is for **/etc/sysctl.d/99-sysctl.conf** :

```
net.ipv4.tcp_syncookies = 1
net.ipv4.ip_forward = 0
```

And the following commands should be ran:

```
sudo sysctl -w net.ipv4.ip_forward=0
sudo sysctl -w net.ipv4.tcp_syncookies=1
```

If **`mysql`** is needed by the README, edit **/etc/mysql/mysql.conf.d/mysqld.cnf** :
under **`[mysqld]`** :

```
bind-address = 127.0.0.1
skip-grant-tables
```

If **`proftpd`** is needed by the README, edit **/etc/proftpd/proftpd.conf** :
```
UseIPv6 Off
DefaultRoot /var/chroot
```

If **`apache2`** is needed by the README, edit **/etc/apache2/conf-available/security.conf** :
```
ServerTokens Prod
```

if you have apache and the old php 7.0, edit ***/etc/php/7.0/apache2/php.ini*** :
```
expose_php = Off
```

If you have ***/var/www/html/webshell.php*** *, delete it.*
```
rm /var/www/html/webshell.php
```

The following is for **Windows**
Most of these involve the Control Panel.

Disabling Dump File Creation

Under System > Advanced > Startup/Recovery > Settings

Set "Write Debugging Information" to "None"

Go to User Accounts and Family Safety > Manage you credentials

Delete all listed credentials until there are no entries in any box. This means removing both Windows and Web credentials.

Under System and Security > Power Options

Require a password on wakeup

User Account Control. This is the screen that pops up when you need administrator access to do something on Windows.

You can enable it under System and Security → Action Center → Change User Account Control settings . Move the bar all the way up to its maximum setting.